

Information Security Risk Register - SecurePay

2025-06-12

Date:

Prepared by: Ubuntu GRC

Methodology: ISO 27005

1. Context Establishment

SecurePay is a FinTech startup in South Africa offering a mobile payment application. Key assets include customer PII, transaction data, the mobile application, cloud infrastructure, and API integrations. The company operates in a highly regulated environment (SARB, POPIA, FICA) and aims for rapid growth while maintaining high security and compliance standards.

2. Risk Identification, Assessment, and Treatment

Risk ID	A sset(s) Affected	Threat	Vulnerability	Existing Controls	Likelihood (1-5)	Impact (1-5)	R L (L
R001	Customer PII, Transaction Data	Unauthorized access to customer database	Weak database access controls, SQL injection vulnerability in API	Basic firewall, password policies	4 (High)	5 (Very High)	2 (C

Risk ID	Asset(s) Affected	Threat	Vulnerability	Existing Controls	Likelihood (1-5)	Impact (1-5)	Risk Level (L)
R002	Mobile Application, Customer PII	Malware on user devices compromising app security	Lack of robust in-app malware detection, users installing apps from untrusted sources	Standard app store security checks	3 (Medium)	4 (High)	12 (High)
R003	Cloud Infrastructure	Service disruption due to DDoS attack	Insufficient DDoS mitigation capabilities	Basic cloud provider DDoS protection	3 (Medium)	5 (Very High)	15 (Critical)
R004	Transaction Data	Fraudulent transactions processed	Weak transaction monitoring and fraud	Manual review of suspicious transactions	4 (High)	4 (High)	16 (Critical)

Risk ID	Asset(s) Affected	Threat	Vulnerability	Existing Controls	Likelihood (1-5)	Impact (1-5)	Risk Level (L)
		through the platform	detection rules				
R005	Customer PII	Data breach due to phishing attack on employees	Lack of employee awareness regarding phishing, inadequate email security	Basic spam filters	3 (Medium)	5 (Very High)	15 (Critical)
R006	All Systems & Data	Non-compliance with POPIA requirements	Incomplete understanding of POPIA, lack of dedicated	Initial POPIA awareness training	3 (Medium)	4 (High)	12 (High)

Risk ID	Asset(s) Affected	Threat	Vulnerability	Existing Controls	Likelihood (1-5)	Impact (1-5)	Risk Level (L)
			compliance officer				
R007	API Integrations	Compromise of third-party banking API leading to unauthorized access	Weak security practices by a third-party provider	Due diligence during vendor selection	2 (Low)	5 (Very High)	10 (High)

Likelihood Scale:

- * 1: Very Low (Rare)
- * 2: Low (Unlikely)
- * 3: Medium (Possible)
- * 4: High (Likely)
- * 5: Very High (Almost Certain)

Impact Scale:

- * 1: Very Low (Insignificant)
- * 2: Low (Minor)
- * 3: Medium (Moderate)
- * 4: High (Major)
- * 5: Very High (Catastrophic - e.g., significant financial loss, reputational damage, regulatory fines)

Risk Level Matrix:

- * 1-4: Low
- * 5-9: Medium
- * 10-16: High
- * 17-25: Critical

3. Risk Acceptance

Risks with a residual risk level of 'Low' (1-4) are considered acceptable. Risks with a residual level of 'Medium' (5-9) will be monitored. Any residual risk above 'Medium' will require further treatment or explicit acceptance by senior management.

4. Risk Communication

This risk register will be communicated to SecurePay's management team and relevant stakeholders. It will be reviewed and updated at least annually, or as significant changes occur in the threat landscape, business operations, or regulatory environment.

5. Risk Monitoring and Review

The GRC Analyst will be responsible for monitoring the implementation of mitigation strategies and the effectiveness of controls. Regular reviews of the risk register will be conducted to ensure its continued relevance and accuracy.